

[doc. web n. 9941763]
Provision of August 3, 2023
Register of provisions
n. 351 of August 3, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data (General Data Protection Regulation, hereinafter, "Regulation");

HAVING REGARD, in particular, to Articles 33 and 34 of
the Regulation titled, respectively, "Notification of
a personal data breach to the supervisory authority" and "Communication of a
personal data breach to the data subject," and Article 32
titled "Security of processing";

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing the
Code regarding the protection of personal data,
as amended by Legislative Decree No. 101 of August 10, 2018 (hereinafter, "Code");

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures of external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data (hereinafter, "Regulation 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's Regulation No. 1/2000 on the
organization and functioning of the Office of the Guarantor for the
protection of personal data;

REPORTING Prof. Pasquale Stanzione;

HAVING REGARD to the notification of a personal data breach from
Onlinestore S.r.l. (hereinafter, Onlinestore or the
"Company") dated March 14, 2023, the supplementary notes of
April 18, 2023, May 3, 2023, May 19, 2023, May 22, 2023, and the response of June 5,
2023, to the request for information made
by the Office, from which it is overall inferred that:
a) Onlinestore operates the e-commerce website www.onlinestore.it
b) On March 11, 2023, Onlinestore received from a
customer a report regarding the presence
on the dark web of a "data leak"
c) the analyses subsequently conducted by the Company
have confirmed that the breach originated from a "hack of the CMS [...] Prestashop
1.7.6.5 [...] with access to the database and export and

publication” that affected “a Backup Server of our CMS Systems, which at the time of the breach was located at the residence of one of our IT employees without an adequate security system at that date”

d) the data subject to the breach included the “first name, last name, address (Street and house number if indicated), postal code, city, email address, date of birth, order history (with purchased products), encrypted password of the user account” of a number of users of the website that the owner assessed as “not determinable,” for a total of “284,000” records of personal data

e) Onlinestore deactivated this server after becoming aware that it had been breached

f) Onlinestore did not communicate the breach to the data subjects pursuant to Article 34 of the Regulation (EU) 2016/679, considering it not likely to present a high risk to the data subjects

g) Onlinestore did not provide the Office with details on any security measures adopted following the breach to prevent further personal data breaches, limiting itself to stating that it had “immediately contacted a specialist (IT expert) to identify the problem”;

CONSIDERING that the Office of the Guarantor has conducted various online accesses aimed at acquiring further elements useful for framing the breach and assessing the risk arising for the data subjects, with particular regard (see the minutes of the operations carried out on July 6, 2023 on file):

1. to the categories of products marketed on the website www.onlinestore.it
2. to the possibility, or not, of finding on the Internet the personal data unlawfully taken from the Company
3. to the security measures in place, with particular regard to any vulnerabilities of the software used by the Company at the time of the breach;

NOTED, at the conclusion of the aforementioned checks, that:

1. Onlinestore markets through its website, among other things, items that may reveal the sexual preferences and inclinations of the buyers
2. portions of the unlawfully extracted personal data from the Company's IT systems are still available on the web, and it is possible to obtain, for a fee, the remaining part of the unlawfully extracted data, for a total volume of 1.8 GB containing the personal data of nine hundred thousand users of the Onlinestore website
3. the version of the PrestaShop software used by the owner on its IT systems at the time of the breach is affected by security vulnerabilities known since July 2, 2020, the date on which the software producer released a

security update;

HAVING REGARD, therefore, both to the statements made from the data controller and from the elements independently acquired by the Office;

HAVING REGARD to the lack of communication of the violation to the interested parties, the "Guidelines on the notification of personal data breaches pursuant to Regulation (EU) 2016/679," according to which the factors to consider in assessing the risk presented by a personal data breach for the rights and freedoms of natural persons include, among others, the type of breach, the nature and number of personal data breached for each affected individual, the ease of identification, and the severity of the consequences for natural persons;

HAVING ASSESSED the breach in question as posing a high risk to the affected parties, due to the nature and number of the breached data, the fact that the loss of confidentiality of addresses and contact details exposes all affected parties to potential significant material and immaterial damages, and the fact that the online availability of the history of orders placed may pose risks of harm to the reputation of the affected parties or discrimination, especially where it consists of items likely to reveal information about the sexual life of the purchasers;

HAVING REGARD to Article 34, paragraph 1, of the Regulation, which establishes that "when a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate the breach to the data subject without undue delay," subject to cases where such communication is not required as one of the conditions set out in paragraph 3 of the same article is met, which is not applicable in this case;

CONSIDERING, therefore, that the data controller is obliged to communicate the breach to the affected parties;

HAVING REGARD to Article 34, paragraph 4, of the Regulation, according to which "if the data controller has not yet communicated the personal data breach to the data subject, the supervisory authority may require, after assessing the likelihood that the personal data breach presents a high risk, that it do so";

THEREFORE, RECOGNIZING the necessity to exercise the Authority's power to order the data controller, pursuant to the combined provisions of Articles 34, paragraph 4, and 58, paragraph 2, letter e) of the Regulation, to communicate the breach to the affected parties, providing at least the information referred to in Article 34, paragraph 2, of the Regulation, "without undue delay" and, in any case, within ten days from the date of receipt of this provision, in order to ensure effective protection for the affected parties;

CONSIDERING, with regard to security measures, that at the time of the breach, methods of processing personal data "without [an] adequate security system" were in use "at the residence of one of our employees"; an outdated version of the PrestaShop software was being used, which was affected by known security vulnerabilities, although more secure versions of this software had long been available; the Company did not promptly indicate to the Office what corrective and preventive security measures it had adopted or intended to adopt following the breach;

THEREFORE, CONSIDERING it necessary to order Onlinestore, pursuant to the combined provisions of Articles 32 and 58, paragraph 2, letter d) of the Regulation, to adopt security measures appropriate to the risks presented by the processing of personal data carried out, including the establishment of a training program for staff on information security and personal data protection, the adoption of software free from known vulnerabilities, and the periodic and timely application of any security updates subsequently made available by the producers of such software;

FURTHER CONSIDERING, pursuant to the combined provisions of Articles 58, paragraph 1, letter a) of the Regulation and 157 of the Code, that the data controller must demonstrate to the Authority that it has complied with the prescribed requirements by providing documented feedback, according to the

following timelines: within ten days regarding communication to the affected parties, and within twenty days concerning the security measures implemented;

NOTING that, pursuant to Article 83, paragraph 6, of the Regulation, "non-compliance with an order by the supervisory authority under Article 58, paragraph 2, is subject to administrative fines of up to 20,000,000 EUR, or for enterprises, up to 4% of the total worldwide annual turnover of the preceding financial year, whichever is higher";

RESERVING, with an independent procedure, any further assessment regarding any sanctioning profiles related to the case in question;

TAKING INTO ACCOUNT that, in any case, pursuant to Article 19, paragraph 6 of Regulation 1/2019, the supervisory activity is preserved in the event of subsequent factual or legal elements or of a different and further assessment by the Authority;

ALL OF THE ABOVE HAVING BEEN CONSIDERED, THE AUTHORITY

orders Onlinestore S.r.l., VAT number 02652600210, with registered office at Via della Palude 15, 39020 Bolzano, certified email onlinestore@pec.bz.it

1) pursuant to the combined provisions of Articles 34, paragraph 4 and 58, paragraph 2, letter e) of the Regulation, to communicate the personal data breach to all affected parties without further delay, and, in any case, within ten days from the date of receipt of this provision, providing the affected parties with at least the information referred to in Article 34, paragraph 2, of the Regulation;

2) pursuant to the combined provisions of Articles 32 and 58, paragraph 2, letter d) of the Regulation, to adopt security measures appropriate to the risks presented by the processing of personal data carried out, including...

****Processing of personal data carried out, including:****

- a. the preparation of a training program for staff on cybersecurity and personal data protection;
- b. the adoption of software free from known vulnerabilities and a program for the periodic and timely application of any security updates subsequently made available by the producers of such software;

****3)**** pursuant to the combined provisions of Articles 58, par. 1, lett. a) of the Regulation and 157 of the Code, to transmit to the Authority:

- a. a documented response regarding the communication to the data subjects referred to in point 1), within ten days from the receipt of this provision;
- b. a documented response regarding the prescriptions referred to in point 2), within twenty days from the receipt of this provision.

It is reminded that failure to respond to this request is subject to an administrative sanction pursuant to the combined provisions of Articles 83, par. 5, lett. e) of the Regulation and 166 of the Code.

Pursuant to Article 78 of the Regulation, as well as Articles 152, paragraph 1 bis of the Code and 10 of Legislative Decree No. 150 of September 1, 2011, an opposition to this provision may be filed with the ordinary judicial authority, with an appeal submitted to the ordinary court of the place where the data controller resides, within thirty days from the date of communication of the provision itself, or within sixty days if the appellant resides abroad.

Rome, August 3, 2023

****THE PRESIDENT****

Stanzione

****THE REPORTER****

Stanzione

****THE SECRETARY GENERAL****

Mattei